

Для скачивания отчета
воспользуйтесь QR кодом.

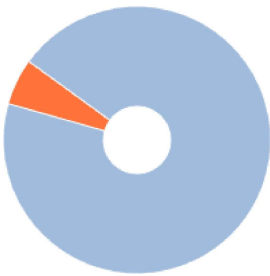


Отчет о проверке

Автор:
Название документа: 17135_2026_01_18_14_22_56_696cecc02c897.docx

Проверяющий: Рязанцева Ирина Павловна
Название организации: Институт управления

РЕЗУЛЬТАТЫ ПРОВЕРКИ



Совпадения:
5.62%



Оригинальность:
94.38%



ИИ-контент:
0%



Цитирования:
0%



Самоцитирования:
0%



«Совпадения», «Цитирования», «Самоцитирования», «Оригинальность» являются отдельными показателями, отображаются в процентах и в сумме дают 100%, что соответствует полному тексту проверяемого документа.

- Совпадения** — фрагменты проверяемого текста, полностью или частично сходные с найденными источниками, за исключением фрагментов, которые система отнесла к цитированию или самоцитированию. Показатель «Совпадения» – это доля фрагментов проверяемого текста, отнесенных к совпадениям, в общем объеме текста.
- Самоцитирования** — фрагменты проверяемого текста, совпадающие или почти совпадающие с фрагментом текста источника, автором или соавтором которого является автор проверяемого документа. Показатель «Самоцитирования» – это доля фрагментов текста, отнесенных к самоцитированию, в общем объеме текста.
- Цитирования** — фрагменты проверяемого текста, которые не являются авторскими, но которые система отнесла к корректно оформленным. К цитированиям относятся также шаблонные фразы; библиография; фрагменты текста, найденные модулем поиска «СПС Гарант: нормативно-правовая документация». Показатель «Цитирования» – это доля фрагментов проверяемого текста, отнесенных к цитированию, в общем объеме текста.
- Текстовое пересечение** — фрагмент текста проверяемого документа, совпадающий или почти совпадающий с фрагментом текста источника.
- Источник** — документ, проиндексированный в системе и содержащийся в модуле поиска, по которому проводится проверка.
- Оригинальный текст** — фрагменты проверяемого текста, не обнаруженные ни в одном источнике и не отмеченные ни одним из модулей поиска. Показатель «Оригинальность» – это доля фрагментов проверяемого текста, отнесенных к оригинальному тексту, в общем объеме текста.

Обращаем Ваше внимание, что система находит текстовые совпадения проверяемого документа с проиндексированными в системе источниками. При этом система является вспомогательным инструментом, определение корректности и правомерности совпадений или цитирований, а также авторства текстовых фрагментов проверяемого документа остается в компетенции проверяющего.

ИНФОРМАЦИЯ О ДОКУМЕНТЕ

Номер документа: 17135

Тип документа: Не указано

Дата проверки: 18.01.2026 19:21:09

Дата корректировки: Нет

Комментарий: не указано

Количество страниц: 53

Символов в тексте: 83261

Слов в тексте: 10535

Число предложений: 662

ПАРАМЕТРЫ ПРОВЕРКИ

Выполнена проверка с учетом редактирования: Да

Выполнено распознавание текста (OCR): Нет

Выполнена проверка с учетом структуры: Нет

Модули поиска: ИПС Адилет, Библиография, Сводная коллекция ЭБС, Интернет Плюс, Сводная коллекция РГБ, Переводные заимствования (RuEn), Переводные заимствования по eLIBRARY.RU (EnRu), Переводные заимствования по Интернету (EnRu), Переводные заимствования издательства Wiley (RuEn), eLIBRARY.RU, СПС ГАРАНТ, Модуль поиска "МГИСУ", Медицина, Диссертации НББ, Перефразирования по eLIBRARY.RU, Перефразирования по Интернету, Патенты СССР, РФ, СНГ, СМИ России и СНГ, Шаблонные фразы, Кольцо вузов, Издательство Wiley, Переводные заимствования, Коллекция НБУ, Перефразирования по коллекции издательства Wiley, Перефразирования по СПС ГАРАНТ: аналитика, СПС ГАРАНТ: аналитика, СПС ГАРАНТ: нормативно-правовая документация, Интернет

ИСТОЧНИКИ

№	Доля в тексте	Источник	Актуален на	Модуль поиска
[1]	1.51%	https://habr.com/ru/companies/arenadata/articles/856366/	01 08 2024	Издательство Wiley
[2]	1.13%	https://habr.com/en/articles/477450/?mobile=yes	28 09 2024	eLIBRARY.RU
[3]	1.02%	https://habr.com/ru/articles/477450/	29 08 2025	Издательство Wiley
[4]	0.97%	https://vk.com/@data4-9-podhodov-vyavleniya-anomalii	08 12 2024	Диссертации НББ
[5]	0.8%	https://selectel.ru/blog/ips-and-ids/	11 04 2024	СМИ России и СНГ
[6]	0.77%	https://vc.ru/education/1789238-problemy-informacionnoi-bezopasnosti-bankov	09 03 2024	Издательство Wiley
[7]	0.73%	https://studfile.net/preview/4431620/	18 02 2025	Издательство Wiley
[8]	0.64%	https://ru.wikipedia.org/wiki/%D0%9A%D0%BE%D1%8D%D1%84%D1%84%D0%B8%D1%86%D0%B8%D0%B5%D0%BD%D1%82_%D0%B4%D0%B5%D1%82%D0%B5%D1%80%D0%BC%D0%B8%D0%BD%D0%B0%D1%86%D0%B8%D0%B8	06 11 2024	Интернет Плюс
[9]	0.64%	https://ru.ruwiki.ru/wiki/%D0%9A%D0%BE%D1%8D%D1%84%D1%84%D0%B8%D1%86%D0%B8%D0%B5%D0%BD%D1%82_%D0%B4%D0%B5%D1%82%D0%B5%D1%80%D0%BC%D0%B8%D0%BD%D0%B0%D1%86%D0%B8%D0%B8	12 05 2025	Кольцо вузов
[10]	0.6%	https://habr.com/ru/articles/475552/	19 03 2024	Перефразирования по коллекции издательства Wiley
[11]	0.58%	https://dokumen.pub/1-i-3341918.html	13 11 2023	Переводные заимствования по Интернету (EnRu)
[12]	0.56%	http://www.machinelearning.ru/wiki/index.php?title=%D0%9A%D0%BE%D1%8D%D1%84%D1%84%D0%B8%D1%86%D0%B8%D0%B5%D0%BD%D1%82_%D0%B4%D0%B5%D1%82%D0%B5%D1%80%D0%BC%D0%B8%D0%BD%D0%B0%D1%86%D0%B8%D0%B8	02 04 2025	Переводные заимствования по Интернету (EnRu)
[13]	0.48%	https://math.uniyar.ac.ru/temy-kursovyh-i-diplomnyh-rabot-kafedry-kompyuternoj-bezopasnosti-i-matematicheskikh-metodov-obrabotki-informacii	24 07 2025	Перефразирования по eLIBRARY.RU
[14]	0.46%	https://math.semestr.ru/corel/prim2.php	01 05 2024	Переводные заимствования
[15]	0.44%	https://fobosworld.ru/koeffitsient-determinatsii-v-excel/	04 08 2023	Коллекция НБУ
[16]	0.35%	https://alexanderdyakonov.wordpress.com/2017/04/19/%D0%BF%D0%BE%D0%B8%D1%81%D0%BA-%D0%B0%D0%BD%D0%BE%D0%BC%D0%B0%D0%BB%D0%B8%D0%B9-anomaly-detection/	28 02 2024	Перефразирования по Интернету
[17]	0.31%	https://rusneb.ru/catalog/000199_000009_02000019760/	07 01 2024	Издательство Wiley
[18]	0.3%	https://codeby.net/threads/uyazvимость-nulevogo-dnya-polnyi-razbor.91685/	26 09 2025	Библиография
[19]	0.29%	https://web-creator.ru/articles/ips	29 08 2023	Коллекция НБУ
[20]	0.27%	https://habr.com/ru/companies/otus/articles/479584/	10 05 2024	Переводные заимствования по eLIBRARY.RU (EnRu)

МИНОБРНАУКИ РОССИИ

Федеральное государственное бюджетное образовательное учреждение

высшего образования

«Ярославский государственный университет им. П.Г. Демидова»

Кафедра компьютерной безопасности и математических методов обработки информации

Сдано на кафедру

« » января 2026г.

Заведующий кафедрой

к.ф.-м.н., доцент

_____ Мурин Д.М.

Выпускная квалификационная работа

Обнаружение аномальной активности в сети на основе анализа статистических отклонений в работе системы

специальность

10.05.01 Компьютерная безопасность

Научный руководитель

старший преподаватель

_____ Савинов Д.А.

« » января 2026 г.

Студент группы КБ-61СО

_____ Сластухин А.Ю.

« » января 2026 г.

Ярославль 2026 г.

Реферат

Выпускная квалификационная работа

«Обнаружение аномальной активности в сети на основе анализа статистических отклонений в работе системы»

Объем 72 страницы, содержит 28 рисунков, 4 приложения, список использованных источников из 17 наименований.

Целью исследования является изучение подходов к построению IDS/IPS систем, классификация направлений анализа аномальной активности. Разработка облегченного алгоритма выявления аномалий для применения как на серверном, так и на клиентском оборудовании.

Построение платформы для сборки IDS систем на базе модульной архитектуры. Реализация IDS системы для анализа статистических параметров в работе системы, включая нагрузку на систему и сетевую активность на базе разработанной платформы.

Методы исследования: теоретический, практический.

Дипломная работа посвящена актуальной проблеме обеспечения информационной безопасности через выявление аномальной активности. В условиях растущего числа кибератак и усложнения методов взлома традиционные сигнатурные методы защиты становятся недостаточными. Предложенный подход, основанный на анализе статистических отклонений в работе системы, представляет современное и перспективное направление развития систем обнаружения вторжений (IDS). Актуальность работы подтверждается необходимостью защиты как корпоративных сетей, так и индивидуальных устройств от новых, ранее неизвестных угроз, которые не могут быть обнаружены статическим анализом.

Ключевые слова: IDS, IPS, аномальная активность, портрет активности, модель активности компьютерной системы, алгоритмы машинного обучения, модульная архитектура, платформа IDS, системное администрирование, обеспечение безопасности

компьютерных систем.

Оглавление

Реферат 2

Оглавление 3

Введение 5

IDS/IPS системы 8

Классификация (По области применения) 8

Классификация (По принципу действия) 9

Сигнатурные 9

Аномальные 9

Сферы применения поиска аномалий. 10

Подходы к выявлению аномалий. 11

Портрет активности 12

Определение 12

Проблемы построения портрета 13

Проблема изучение аномалий в поведении человека-системы 13

Построение анализатора IDS системы 15

Постановка задачи 15

Архитектура анализатора 16

Базовый анализатор 18

Метрика оценка качества модели 19

Алгоритм корректировки весов 19

Алгоритм подбора весов 20

Общие рекомендации по выбору оптимального шага 21

Результат 22

Применение алгоритма при решении задачи выявления аномалий для датасета TelecomX 23

Описание 23

Соглашения 24

Выбор модели данных, предобработка грязных данных. 24

Конфигурирование анализаторов 24

Обучение и анализ 25

Анализ аномальной активности пользователя 5828 25

Анализ с точки зрения злоумышленника 28

Итог по TelecomX 29

Дальнейшее развитие системы 29

IDS система для работы с реальными данными 30

Архитектура источника данных 30

Модель данных подсистемы представления 32

1.Анализ статистической активности системы-пользователя 33

2.Переферийный анализ активности пользователя 34

Возможные направления для решения задачи анализа периферийных устройств 36

Сбор активности с конкретного устройства 37

Выбор модели подсистемы представлений 38

WHOIS 41

Полная модель хранения данных 43

Демонстрационная модель на базе NoSql 44

Структура файла для MongoDB хранилища 44

Опасность глубокого сбора информации по пользователю 46

Подсистема анализа 46

Подсистема уведомления 46

Архитектура клиент-серверного взаимодействия 46

Модель UI 47

Демонстрация работы в серверном режиме 50

Заключение 55

Литература 57

Приложение А. Описание репозитория 59

Приложение Б «Реализация логгеров» 60

API и точка запуска 60

Бизнес логика 61

AbsoluteDictStat 62

ScheduleLogger 63

Приложение В Реализация сервиса представлений 64

Точка запуска и API 64

Бизнес логика 65

Приложение Д Реализация анализатора 66

Алгоритм анализа 69

Введение

В последние десятилетия, в связи с активным развитием технологий, в частности, персональных компьютеров и сети интернет, у человека появился доступ к огромному океану различной информации, многие проблемы стали решаться в несколько кликов мыши. Это привело к тому, что и злоумышленники получили в своё распоряжение отличные инструменты для совершения зловредных действий.

Например, с 1960-х до середины 1980-х телефонные хулиганы часто звонили из телефонных автоматов, в пределах ограниченной местности, с учётом того, что себестоимость услуги компании была близка к 0, а число подобных инцидентов было мало, телефонные компании не теряли в прибыли насколько, что могли игнорировать проблему.

Или подделка долларовых банкнот: спецслужбы США выяснили, что в руки злоумышленников попало определённое число старых печатных машин, способных печатать доллары США. Оценили общее число машин и их производительность и пришли к выводу, что общий ущерб является каплей в море.

А теперь представьте, как с развитием технологий всё изменилось — достаточно одному злоумышленнику придумать способ, даже неэффективный, для получения 1 цента и выложить программу в интернет — финансовая система может быть уничтожена, поскольку

технические возможности распределённой системы злоумышленника оцениваются сверху всеми устройствами в сети.

Природа атак не изменилась с развитием техники, старые подходы, способы обмана и хищения используются при новых инструментах, но старые методы защиты частично перестали работать из-за возросших требований. Мы так же пытаемся обезопасить свои личные устройства или корпоративные сети, но проблема в том, что на любое средство защиты найдётся способ его обойти. Один из подходов к решению возникших проблем, помимо защиты сети в целом с помощью различных брандмауэров и фильтров, будем рассматривать защиту отдельно взятых устройств - это подобно личной гигиене, отсутствие которой в средние века выкашивало целые поселения – так и сейчас, защитив отдельно взятые устройства, мы можем значительно снизить ресурсы сети, которые могут быть взяты под контроль, сможем снизить потенциальный ущерб.

Среди способов защиты традиционно выделяется статический анализ – кто-то когда-то уже подвергся нападению и выявил уязвимость, оповестил остальных и системы скорректировали. Эффективность этого подхода в том, что большинство инцидентов проходит мимо нас, но мы перекладываем ответственность на кого-то другого, кто сможет выявить угрозу и всех оповестить, считаем, что наши устройства никому не нужны – идейно, это работает неплохо, но существует несколько проблем:

- новая угроза может быть не выявлена статическим анализом
- кто-то не оповестит других, посчитав, что найдётся более опытный специалист, кто справится с проблемой за него – перекладывание ответственности

и угроза за короткое время распространиться по сети, нанесет ущерб, как обычным пользователям, так и крупным компаниям.

Поэтому выделим альтернативный подход – основанный на следующей идее: Различные пользователи обладают своим характером, потребностями, целями, знанием и опытом, решают свои задачи.

Например, увлекаются выпечкой или разрабатывают приложение на Python.

Так и компьютерные системы крупных компаний тоже обладают своими особенностями, связанными с их родом деятельности.

Например, если сервер компании занимаются массовыми рассылками, не производя сложных вычислений, то будет странно, если вдруг он станет решать несколько тяжёлых задач.

Опираясь на данные об их нормальной активности, логично пытаться делать выводы об аномальности в конкретный момент времени.

На первый взгляд, с людьми этот подход не работает – человек более сложный механизм, поэтому требуется комплексно подходить к вопросу изучения человека.

Однако изменения в жизни и характере человека чаще происходят постепенно, и если происходят стремительно, то их нельзя оставлять без внимания.

Заметим, что у всех аномальных систем есть общая проблема – они либо находят «аномалии» слишком часто и им перестают верить, либо не находят. Будем считать, что удалось найти баланс.

Даже так система имеет недостаток – индивидуальный подход к каждой системе аномального типа при достаточной подготовке злоумышленника и наличии времени может не сработать.

Люди меняются в течение жизни и машины тоже – система должна отлавливать изменения, но не реагировать на незначительные изменения.

В этом главная уязвимость – постепенными незначительными изменениями возможно полностью исказить «нормальность», аномалии превратятся в норму.

Заметим, что решение подобной задачи на стороне злоумышленника требует в каждом конкретном случае индивидуального подхода – обойти систему анализа, каждый раз новая задача.

Вывод: системы поиска аномалий интересное направление, но их одних недостаточно - нужно использовать статический анализ совместно с анализом аномалий. Статический защитит от известных угроз, а основанный на аномалиях, выявит потенциально опасное действие или выиграет время на обнаружение зловреда.

О том, какие подходы к анализу аномалий существуют, какие проблемы возникают, эффективны ли эти подходы поговорим в рамках работы.

По итогу предложим кроссплатформенную систему выявления статистических аномалий на основе активности операционной системы.

IDS/IPS системы

IDS (Intrusion Detection System) - система обнаружения вторжений.

IPS (Intrusion Prevention System) - система предотвращения вторжений.

IPS является сложным, комплексным решением, которое может сочетать в себе, анализ файлов, как это делает антивирус, контроль трафика и работу с правилами сетевого взаимодействия, как это делает фаервол.

Классификация (По области применения)

- Network Intrusion Detection System (NIDS) - контролирует работу в сети, взаимодействие нескольких хостовых узлов.
- Host-based Intrusion Detection System (HIDS) – работает на конкретном хосте, не имеет доступа к другим узлам.

NIDS по своей идее очень похожа на фаервол, просматривает весь входящий и исходящий трафик, но является более мощным инструментом, поскольку может находить глубокие признаки аномальной активности.

Основным минусом является тяжеловесность – для глубокого анализа на наличие угроз, найденных в взаимодействии различных узлов, требуются значительные вычислительные мощности, сопоставимые с мощностями всей системы, а часто и превышающими её, поскольку часто требуется обработать всё, что происходит в сети.

Часто NIDS нацелены именно на анализ сетевого взаимодействия в то время, как HIDS анализируют всё, что происходит на конкретном узле, включая трафик, файловую систему, журналы событий – таким образом, NIDS ставят на всю сеть, а на критически важные точки ставят HIDS.

Дополнительно¹⁹ выделяют:

- PIDS (Perimeter Intrusion Detection Systems)¹⁸ – подобно фаерволу контролируют только периметр сети, а не всю сеть.
- VMIDS (Virtual Machine-based Intrusion Detection Systems)⁶ – принципиальным отличием является⁶ то, что устанавливается на устройство,¹⁸ а на виртуальную машину, что позволяет быстрее её переносить.

Классификация (По принципу действия)

Сигнатурные

Анализируют текущее состояние системы на предмет нахождения уже известных сигнатур угроз. В этом отношении⁵ такие системы пересекаются с антивирусами, имеют минус – не реагируют на новые уязвимости. Поэтому требуется⁶ своевременное получение информации⁶ о новых уязвимостях.

Сигнатурой называется шаблон уже известной угрозы.

Помимо сигнатур выделяют *состояния*: в начальный момент времени считаем, что система в безопасном состоянии, но каждое действие в системе: несанкционированное действие пользователя, сетевое обращение, установка и активация ПО, особенно драйверов, может привести в скомпрометированное состояние. Очевидно, что NIDS часто отслеживают сигнатуры, а HIDS состояния.

Аномальные

Аномалией является любое действие, которое по каким-то признакам отличается от нормы, что даёт возможность предполагать, что система могла перейти в⁶ скомпрометированное состояние.

Аномалии делятся на:

- Статистические – сопоставляют профиль штатной работы текущим. Используют статистические алгоритмы. Например, в текущем профиле повышена нагрузка на сеть или диск, число операций, интервал между ними – снижены или наоборот повышены. Всё, что указывает на нарушение штатной работы.
- Поведенческие – части системы пытаются выполнять функции, которые им не предусмотрены или нарушается порядок выполнения, например, есть приложение пытается отправить результат⁵ до того, как задача была выполнена, или же штатный⁵ протокол используется не по назначению.
- Аномалии трафика – статистически трафик может быть штатным, но в нём могут присутствовать нетипичные особенности.

Аномалии могут иметь черты разных типов – это может быть аномалия трафика, в которой помимо угрожающей активности может присутствовать нарушение профиля штатной активности.

В рамках текущей работы особый интерес представляют именно системы, работающие с аномалиями. Они более сложные, разнообразные, наукоёмкие с точки зрения используемых подходов, тяжеловесные с⁵ точки зрения требуемых ресурсов.

Системы поиска аномалий способны помочь выявить новую угрозу, в то же время они не дают никакой гарантии, что в принципе сработают, в то время как сигнатурные гарантируют, что конкретные сценарии практически недостижимы.

Сферы применения поиска аномалий.

Прежде, чем изучать способы выявления аномалий, рассмотрим несколько сфер возможного применения выявления аномалий:

1. *Анализ штатной активности уже работающих систем* – в 2010 году сетевой червь *Stuxnet* атаковал иранское предприятие, изменив настройки оборудования, привёл к преждевременному выходу из строя центрифуг для обогащения уранового топлива. Есть веские причины полагать, что вирус был разработан при сотрудничестве США и Израиля с целью саботировать иранскую ядерную программу – если бы система контроля учитывала штатную активность оборудования, экономических и стратегических потерь можно было бы избежать.

2. *Выявление аномальных потребительских паттернов или мошеннических действий* – пользователь Боб периодически совершает переводы Алисе. В случае если Боб попытается перевести Алисе сильно больше, чем он делает обычно или попытается сделать перевод в другую страну, хотя обычно он совершает переводы в рамках своего города – банковская система должна отреагировать и запросить дополнительное подтверждение или заблокировать операцию.

3. *Рекомендательные системы* – бывает очень важно отвечать на вопрос, понравится ли пользователю той или иной продукт, опираясь на профиль его активности – какие категории товаров он смотрел в последнее время, что купил – важно предоставить пользователю связанные товары: купил человек подгузники, вероятно у него есть ребёнок, можно в ленту добавить детское питание, одежду, игрушки.

Возникает вопрос – при чём тут аномалии?

Рекомендательная система может быть преобразована в детектор аномалий.

Например:

- штатная активность пользователя – это основа для рекомендательной системы, аналог просмотрам и покупкам.
- новое действие пользователя – это то, чему система даёт оценку.
- результат работы – если действие может считаться рекомендованным, то штатный профиль активности не нарушен, иначе это аномальная активность.

Возникает вопрос, что первично, а что вторично – сложный вопрос, скорее всего, это одна и та же сущность, рассмотренная под разные сферы применения.

Отмечу, что практические вопросы, возникающие при построении рекомендательных систем, не менее трудные, как и проблемы построения систем выявления аномалий – почва для глубоких исследований эффективных подходов.

Приходим к выводу, что поиск аномалий – важная задача.

Подходы к выявлению аномалий.

Важно понимать, что выявление аномалий нетривиальная задача – существует множество алгоритмов, но в большинстве они используют методы, которые описаны ниже.

1. Метод опорных векторов с одним классом One-Class SVM

Подходит, когда в обучающем наборе данные подчиняются нормальному распределению, а в тестовом содержат аномалии.

Считается, что этот подход наиболее часто применимый при поиске аномалий.

2. Метод изолирующего леса – isolate forest

Опирается на то, что при «случайном» построении деревьев выбросы будут попадать в листья на ранних этапах (на небольшой глубине дерева), т.е. выбросы проще «изолировать». Выделение аномальных значений происходит на первых итерациях работы алгоритма.

3. *Elliptic envelope* и другие статистические методы.

4. Метрические методы

5. Кластерные методы

6. Метод главных компонент

7. Методы на базе прогнозирования временных рядов – если рассматриваемое значение выбивается из временного ряда, то значение

считается аномальным.

8. Обучение с учителем — регрессия и классификация

9. Методы на базе алгоритмов² решения задач рекомендаций.

Решение² задачи поиска² аномалий часто требует² индивидуального подхода к конкретной проблеме — это искусство, требующее своевременного применения различных знаний.

Более того, доказано, что не существует универсального решения для борьбы с вирусами, сетевыми угрозами — для любой существующей системы можно² предложить подход,¹⁶ позволяющий обойти алгоритмы детектирования. Таким образом различные методы применяются совместно — группируются, в зависимости² от системы.

Пример: анализаторы сетевого трафика Positive Technologies представляют целые цепочки анализаторов, построенные для максимально эффективного использования вычислительных ресурсов — не забываем, что решение задачи поиска угроз требует затраты, сопоставимые с содержанием такой же системы.

Портрет активности²

Прежде, чем приступить к реализации обсудим важные понятия и возможную архитектуру подобных систем.

Вводя² понимание портрета, рассуждаем о том, как работает человеческое² мышление — это сильный² механизм, его поведение можно смоделировать.

Определение²

Представим, что система подобно человеку² имеет некоторые поведенческие особенности, по которым её можно отличить² от другой системы.

При этом² эти особенности не обязательно уникальны⁴ — множество систем может им соответствовать.

Замечание: как отпечаток пальца человека не является его поведенческой особенностью, так и имя или адрес системы не являются её поведенческой особенностью, это уникальный идентификатор, позволяющий выделить среди остальных, поэтому мы будем анализировать именно действия системы.

Вспомним хорошо известного знакомого и будем накладывать на него различные поведенческие модели — в некоторых ситуациях, мы согласимся «действительно, похоже», в других скажем «точно нет», в оставшихся засомневаемся.

Рассуждения могли быть следующие:

- взять все известные факты об изучаемом объекте — это его портрет
- сопоставить известный портрет с исследуемым действием, отвечая на вопросы соответствия портрета действию ответами — «Да», «Нет», «Не знаю».

«Портрет» (или «модель активности») — это совокупность фактов об изучаемом объекте, каждый из которых может быть использован для построения характеристики/статистики, которая отразит характерные черты, особенности изучаемого.

От полноты, достоверности и непротиворечивости портрета будет зависеть «чёткость» портрета (или «точность» модели) — некоторые детали могут быть чёткими, некоторые размытыми, а некоторые вовсе неопределёнными.

С системами аналогично, предполагаем, что, анализируя активность системы, можно построить портрет, который позволит отличать нормальное поведение от аномального.

Далее формализуем введённое понятие «портрет» и будем говорить в терминах модели.

Проблемы построения портрета:

1. Проблема полноты — в зависимости от постановки требований необходим разный объём данных, в противном случае модель не покроет весь объём возможных сценариев.
2. Проблема достоверности — от достоверности используемых фактах, зависит точность модели.
3. Проблема непротиворечивости — противоречия всегда опасны, их особенно тяжело анализировать. Согласно теореме «о непротиворечивости» из логики высказываний, нельзя одновременно доказать утверждение о его отрицание в непротиворечивой системе. Из одновременного выполнения утверждения и его отрицания следует всё, что угодно. Однако сам факт наличия противоречивых особенностей можно использовать как характеристику изучаемого объекта.

4. Проблема изменчивости – всё течёт и меняется. В зависимости от политики, если потрет адаптируется автоматически, не уведомляя об аномалиях, то у злоумышленника появляется множество последовательных незначительных изменений исказить исходный портрет, при этом каждое изменение может укладываться в доверительные интервалы.
5. Проблемы ложных срабатываний – если система будет реагировать на допустимые незначительные изменения жёстко, которые допустимы, система анализа потеряет доверие, к её выбросам не будут прислушиваться. Это ещё одно место для эксплуатации злоумышленником – если злоумышленник не может обойти системы своими силами (т.е. его аномальные действия всегда обнаруживаются), он может генерировать аномальную активность на пограничном уровне так, что владельцы системы при некоторых стечениях обстоятельств могут перестать доверять системе, выключить её.

Большинство проблем возникают из-за недостоверных данных или неправильной политики, подобрать которую оптимально представляется возможным в индивидуальном порядке – человеческий фактор является камнем преткновения любой самой надёжной системы защиты.

Проблема изучение аномалий в поведении человека-системы

Заметим, что промышленными системами ситуация проще, ведь они более инертны и предсказуемы – если почтовый сервер стал выполнять тяжёлую вычислительную задачу вместо множества маленьких – это повод расследовать.

С людьми тяжелее, они менее предсказуемы, но системы, которые они используют, отражают их индивидуальные особенности – поэтому важно, понимать, как изучать людей, чтобы изучать деятельность их систем, в свою очередь выявление аномалий в действиях системы может помочь выявить негативные аномальные изменения в человеке – например, что он заболел, что у него снижена реакция и концентрация внимания, что на привычные задачи он тратит слишком много времени - это может быть интересно в целях обеспечения как техники безопасности, так и противодействия вторжению, когда вместо ожидаемого человека от его лица работает кто-то другой.

Именно на проблеме выявления аномалий в деятельности человека-систем я и буду делать акцент в текущей работе. Поскольку продвинемся в решении сразу нескольких задач – обеспечения безопасности как отдельных узлов сети, так и всей сети целиком, так и изучение человеческого мышления.

Построение анализатора IDS системы

Перед построением нужно обязательно определиться с моделью обрабатываемых данных – это крайне сложный вопрос, намного более сложный, чем выбор анализатора или проектирование архитектуры. На текущем этапе будем считать, что объём получаемого и передаваемого трафика мы точно можем получить. Но позже в работе обязательно спроектируем конкретную модель данных, которая охватит не только трафик, но и работу с диском, управление процессами и потоками, общую нагрузку, а в LINUX можно будет даже анализировать изменение скорости вращения вентиляторов охлаждения.

Перед разработкой системы нужно определиться с ядром – анализатором, если окажется, что он не в состоянии решить поставленные задачи, то дальнейшая разработка не имеет смысла.

Если заранее известна модель данных, можно выбирать из различных алгоритмов машинного обучения – каждый из них хорош по-своему, они изучены и математически подкованы. Очевидно, что с их помощью можно проводить анализ.

Но давайте рассмотрим, как может быть устроен примитивный анализатор, который будет сочетать в себе идеи алгоритмов машинного обучения, но при этом будет прост, быстр и сможет решать поставленные задачи – в будущем, в построенную систему без труда можно будет внедрить любой анализатор.

Постановка задачи

Цель: построить универсальный базовый анализатор для поиска статистических аномалий активности.

Под универсальностью понимаем следующее: пользователь, уровня продвинутого разработчика или системного администратора получит инструмент, для работы которого потребуется передать модель данных DataFrame в формате .csv или .txt.

По входной модели потребуется настроить анализаторы (Analyzers).

Analyzers, как сущности предопределены, их потребуется выбрать и настроить параметры, от которых будут зависеть, насколько резко система будет реагировать на изменение портрета активности.

Разработанный анализатор будет поставляться как библиотека на языке C#.

Анализатор будет принимать входные данные, формировать список вложенных анализаторов, автоматически подгонять веса под каждый конкретный датасет – тк очевидно, что для каждого случая разные анализаторы могут быть более эффективны. Предполагаем,

что пользователь заранее не знает, какие анализаторы имеют больший вес — часто это действительно так, бывают неочевидны некоторые зависимости.

Архитектура анализатора

Рисунок Интуитивная модель анализатора

1. Считывающие устройства — оборудование, коммутаторы, маршрутизаторы, перехватчики трафика, например, Wireshark и т.п.
2. Модель грязных данных — полученные при считывании с устройств, часто это разрозненные данные (смешанные, разных форматов), непригодные для обучения.
3. Преобразователь — преобразует грязные данные в данные, пригодные для обучения.
4. Модель обучающих данных — подготовленные, сгруппированные, одного формата.
5. Analyzer - устройство по модели чёрного ящика, которое каким-либо образом учитывает обучающие данные, и способно выдавать результат для новых данных.

Замечание: Analyzer может быть представлен комбинацией анализаторов.

Рисунок Модель множества анализаторов

Анализ отражается следующей схемой:

Рисунок Модель комбинированного анализатора

Каждый из анализаторов независимо от других предоставляет результат $\in [0, 100]$

Результат — это уровень доверия, если он 100, то анализатор не считает данные аномальными.

У каждого анализатора есть вес в принятии общего решения .

Замечание: в данном анализаторе нет ограничения .

Возможны варианты, когда оно есть, но в данный момент считаем, что разные комбинации анализаторов на разных данных могут дать положительный результат, поэтому это ограничение отбрасываю — это место для исследования или для выделения в опцию (может быть актуально, если при анализе важна строгость).

Базовый анализатор

В построенной библиотеке есть предопределённые базовые анализаторы, которые можно использовать, как для анализа данные, так и для расширения — для создания собственных анализаторов за счёт наследования от базовых.

Базовый анализатор имеет следующий минимальный интерфейс:

1. `public bool Filter(DataFrameRow row)` — метод фильтрации, позволяет отсеять данные, которые непригодны для обучения этим анализатором.

Например, строковый анализатор ничего не может сказать по пустому значению.

1. `public PredictInfo Estimate(DataFrameRow row)` — метод предсказания.

`PredictInfo` — обёртка для результата, включает в себе помимо результата, используемые анализаторы и обоснование оценки, для удобства анализа.

1. `public void LoadRow(DataFrameRow row)` — метод внесения достоверных данных.

Каждый анализатор может быть представлен логической комбинацией других анализаторов:

- группой, где у каждого есть коэффициент влияния,
- комбинацией — для того, чтобы анализаторы можно было использовать только совместно или использовать по правилу ИЛИ с одним общим весом.

Но в общем, каждый анализатор может рассматриваться как отдельный, независимый от других, со скрытой реализацией, главное, что они соответствовали общему интерфейсу.

Замечание: Успех использования библиотеки зависит от того, как в каждой конкретной задаче будет выстроен используемый анализатор — универсального решения нет, это большая задача, наравне с тем, какую модель входных данных использовать — алгоритм подберёт оптимальные веса, но от разработчика требуются осмысленные решения.

На текущую версию доступны следующие базовые анализаторы:

1. IdAnalyzer — идентификаторы, самый простой анализатор.
2. ArrayAnalyzer — позволяет группировать идентификаторы, например — идентификаторы продуктов в чеке или список получателей сообщения.
3. NumberAnalyzer — числовые значения, т.к. числа непрерывны, то хранить их может быть сложно, поэтому подвергаются квантованию по уровню, что позволяет эффективно хранить и использовать на новых, не встречаемых ранее, значениях.
4. StringAnalyzer — строковые значения, из строки выделяются корни слов, сортируются и рассматриваются как ArrayAnalyzer — подход позволяет эффективно хранить, но из-за сортировки и отброса частиц, таких как НЕ, теряется смысл исходного значения.

Текущие базовые анализаторы примитивны — все построены на эффективных словарях, работа с которыми инкапсулирована в сущность History (попытка воспроизвести примитивную модель человеческой памяти), но это обеспечивает высокую скорость работы и низкие размеры моделей.

В будущем планируется расширить базовый набор за счёт использования алгоритмов машинного обучения, многие из которых указаны выше.

Метрика оценка качества модели

Опр: RSquared (Коэффициент детерминации) — метрика для оценки качества модели, принимает значение от нуля до единицы.

Чем ближе значение коэффициента к 1, тем сильнее соответствие.

- Для *приемлемых* моделей предполагается, что коэффициент детерминации должен быть хотя бы не меньше 50 % (коэффициент корреляции превышает 70 %).
- Модели с коэффициентом детерминации выше 80 % можно признать *хорошими* (коэффициент корреляции превышает 90 %).
- Значение коэффициента детерминации 1 означает функциональную зависимость между переменными.

Можно интерпретировать как соответствие модели данным — насколько хорошо модель отражает следуемые данные.

Алгоритм корректировки весов

Определим алгоритм корректировки как:

Вход:

- expected, current - ожидаемый и фактический результат,
- weights - текущий набор весов.

Выход:

new_weights — скорректированный набор весов.

В нашем случае алгоритм подбора весов реализуется, как

1. Вычислить общую ошибку, как разность ожидаемого результата и текущего:
2. Вычислить значение сигмиды:
3. Вычислить значение корректировочного коэффициента:

Параметр отвечает за скорость, с которой вес будет скорректирован. Параметр перебирается в процессе тренировки, тк в зависимости от обучающей выборки он может быть разным.

delta — коэффициент для корректировки общего анализатора, но он состоит из нескольких анализаторов — требуется распределить корректировочное значение.

used_analyzers — анализаторы, которые принимали участие в полученном результате.

Анализатор может 10 дать ответ («не знаю»), в таком случае он не учитывается в корректировке весов.

1. Корректировочное значение для веса анализатора:
2. Новое значение веса анализатора:

Алгоритм подбора весов

Определим полный алгоритм, который выполняет подбор весов для датасета.

Этап 1 (Инициализация):

1. Разбивается общий набор обучающих данных на тренировочные (30%) и эталонные (70%).
2. Эталонные данные загружаются в анализатор.

Этап 2 (Подбор весов):

Генерируется случайный вес для каждого анализатора – изначально не известно какой анализатор лучше отражает особенности исследуемого датасета, но в процессе корректировки весов выявляется эта зависимость.

Если анализатор бесполезен, то его ни разу не используют для корректировки весов или его вес окажется мал по результатам тренировки.

Замечание: в последствии откажемся от случайной генерации начальных весов – будто это не вносит никакой пользы, является рудиментом первых версий.

1. Считается значение качества модели RSquared.
2. Цикл, по тренировочным данным:
 1. Предсказывается результат для текущей записи ([0, 100+]).
 2. Срабатывает алгоритм корректировки весов.

Этап 3 (Повторение этапа 2):

В частности, перебор шага обучения `learn_step` и попытка сгенерировать более подходящие начальные веса.

Наблюдение: в большинстве тестов шаги 0.5-1 чаще других выдавали лучший результат.

Этап 4 (Сохранение наилучших весов)

Общие рекомендации по выбору оптимального шага

Размер шага отражает скорость, с которой вес корректирует в том направлении, в котором требует конкретная запись.

Рассмотрим отвлеченный пример:

1. Анализатор выдал значение 70, а ожидалось 100
2. Ошибка 30 – мы можем сразу сдвинуть веса, чтобы результат стал 100 за 1 корректировку, но тогда, очевидно, что пропадает смысл прогонять по датасету – т.к. последняя запись скорректирует веса под себя.
3. В зависимости от шага можем скорректировать веса так, чтобы результат приблизился к ожидаемому, например, 71 – 75.

Тем самым обеспечиваем плавность изменений, понижаем влияние плохих данных на итоговый результат:

1. Плохая запись сдвинет результат в ложную сторону, но остальные 10 скорректируют в верном направлении.

Очевидно, что при выборе шага следует учитывать процент плохих данных в датасете.

Если окажется, что из 100 в датасете 5 плохих и для них будет выполнена корректировка в самом конце, то при большом шаге они смогут смести итоговые веса в свою пользу.

Введём понятие: «Критическое подмножество» - минимальное подмножество обучающего датасета, при корректировке для которого веса учитывают только требования этого подмножества.

Понятие определено формально, оценивать его можно приблизительно для каждого случая – оно позволяет выбрать шаг обучения так, чтобы размер критического подмножества приближался к размеру всего датасета.

В будущем в систему добавим автоматическую оценку критического подмножества — предполагаем, что её можно оценить математически, опираясь на формулы корректировки.

Рекомендации по выбору веса:

- 0.5 — 1 оптимально для датасетов с небольшим размером - до нескольких тысяч
- > 1 может дать хороший результат на датасетах меньше 100
-

Перебор шага в процессе обучения позволяет решить проблему влияния критического подмножества за счёт оценки результата точности модели — если критическое подмножество сдвинуло веса в свою пользу, то оценка будет плохой, т.к. остальные записи окажутся отдалены от ожидаемого результата.

Результат

Построена библиотека, позволяющая сконфигурировать решения задачи выявления аномалий на произвольном датасете.

Ключевым фактором успеха является решение задач:

1. Сформировать модель данных для анализа — если она не будет коррелировать с реальными аномалиями, то система их не сможет найти.
2. Сконфигурировать систему анализаторов из предложенных базовых.

Решение описанных задач требует индивидуального подхода, поэтому возлагаются на разработчика, который будет внедрять систему. Система в будущем должна быть удобной и значительно автоматизировать многие рутинные процессы, связанные с решением поставленных задач — например, предложить автоматическую конфигурацию по произвольному датасету, которую в последствии нужно будет только скорректировать.

Полученную библиотеку стоит протестировать на предмет способности решать задачу поиска аномалий.

Рассмотрим применение библиотеки на примере датасета TelecomX, который отражает промышленные особенности промышленных систем передачи трафика.

Применение алгоритма при решении задачи выявления аномалий для датасета TelecomX

Описание

В качестве датасета буду использовать датасет, сгенерированный для хакатона по обработке больших данных в 2024 году.

Постановка задачи:

«С линейного оборудования узлов связи раз в какое-то время (например, раз в 10 минут) снимаются логи, содержащие информацию об интернет-соединении абонентов:

- номер сеанса связи,
- дата начала,
- дата конца,
- продолжительность сеанса,
- номер абонента,
- количество скачанного и переданного им трафика.

Когда данные прилетали на хранилище, они обрабатывались аналитическим pipeline для выявления аномалий потребления трафика абонентами за последнее время.

В частности, если характер потребления трафика кардинально изменился в сторону увеличения потребления по сравнению с предыдущим *за аналогичный период*, то есть подозрение на то, что оборудование абонента взломано и превратилось, например, в узел DDOS-сети или в спам-сервер.

Такой pipeline запускался каждый час, и ¹результатом его работы была плоская таблица — витрина данных, в которой представлен список работавших в последний час абонентов (с их контактными данными) и их предполагаемый статус: was hacked или нет.»

Кейс построен на основе реального опыта специалистов.

В данный момент создано три набора: ¹

- Telecom10k — телеком-компания с 10 000 абонентов, 1 млн записей, 51 Мб данных.
- Telecom100k — телеком-компания с 100 000 абонентов, 11 млн записей, 688 Мб данных.
- Telecom1000k — телеком-компания с 1 000 000 абонентов, 117 млн записей, 7,2 Гб данных

Соглашения

- Вместо анализа последнего часа проанализируем несколько часов с целью выявить устойчивое отклонение в работе системы.
- Весь процесс анализа, включающий предобработку инкапсулированы в сущности TelecomX.

Выбор модели данных, предобработка грязных данных.

На вход приходит «грязный» объём данных — каждое оборудование, снимающее логи, передаёт данные в необработанном виде, имеется информации о сессиях различных пользователей в течение 10 минут.

Для составления портретов активности нужно провести агрегацию данных по каждому пользователю в разрезе каждого часа.

Модель для анализа имеет следующий вид:

1. Пользователь
2. Дата анализируемого часа
3. Число сессий
4. Переданный трафик
5. Полученный трафик
6. Продолжительность

Пункты 4-6 особенные, т.к. при агрегации мы должны выбрать подход:

- Общая сумма по всем сессиям
- Медианное значение
- Максимальное значение

Пункты 1-2 будут нести информационный характер, в процессе анализа не учитываются.

С учётом того, что алгоритм позволяет подобрать оптимальные веса, то будем использовать параллельно все подходы для пунктов 4-6, предполагая, что для каждого пользователя может играть роль своя метрика.

По итогу предобработки для каждого пользователя сформирован свой файл .csv, в котором хранятся сущности, готовые к анализу.

Конфигурирование анализаторов

С учётом того, что анализируемые метрики (Число сессий, продолжительность, объём переданного и полученного трафика) — числовые, то все анализаторы будут иметь тип NumberAnalyzer, настройки по умолчанию, составные анализаторы не применяются.

Обучение и анализ

Для каждого пользователя по отдельности на его данных обучается портрет активности. Процесс обучения включает загрузку эталонных данных и автоматический подбор весов для каждого анализатора.

Результатом является портрет (общий анализатор), определяет уровень доверия к действиям пользователя.

Замечание:

При текущей реализации на базе эффективных кэшей есть как плюсы, так и минусы.

При необходимости загрузить новые данные в портрет не требуется обязательного перераспределения весов — хотя, конечно, периодически это делать стоит.

При такой реализации требуется решить задачу откидывания «странных», редких данных в обучающем датасете — это позволяет выделить скелет, основные черты пользователя, но портрет потеряет детали (мелкие черты тоже важны).

Отбрасывание частично решает проблему, но это потенциальная точка для эксплуатации злоумышленником, при этом, использовать все имеющиеся данные так же опасно — позже увидим, почему.

В текущей реализации «странные» значения не отбрасываются автоматически.

Обучив модели 635 пользователей, и проанализировав статистику их трафика за последние 6 часов, удалось выявить 3 пользователя с устойчивыми аномалиями — за 6 часов, модель зафиксировала более 2-х аномалий, т.е. более 50% времени за последние 6 часов, активность была аномальной.

Анализ аномальной активности пользователя 5828

Сначала приведены графики изменения статистических показателей.

Жирными точками выделены значения, где была зафиксирована аномальная активность — это не означает, что аномалия на конкретном графике, а лишь указывает на то, что в это время система зафиксировала аномалию, графики отражают изменение показателей.

Как эти показатели используются системой — графики не отражают.

В конце приведён график, на котором показан уровень доверия к действиям конкретного пользователя

Пользователь 5828 (зафиксирована аномалия):

Рисунок 4 Пример корректного графика, общая продолжительность сессий пользователя 5828.

Интуитивно понятно, что на представленном графике аномалии нет.

Он показал высокий уровень доверия.

Рисунок 5 Пример аномального графика. Общий объём входящего трафика для пользователя 5828

Аналогичные рисунку 2 — графики отправленного трафика — наблюдается скачок, который не соответствует нормальной активности пользователя, при этом число сессий и продолжительность не изменились.

Как мы видим по рисунку 1, продолжительность в норме, но, исходя из анализа других параметров видно, что объём входящего и исходящего трафика превышает норму, поэтому фиксируется аномалия.

Далее рассмотрим график уровня доверия модели к действиям пользователя.

Рисунок 6 Изменение уровня доверия к действиям пользователя 5828

Вопрос: Почему более ранний аномальный пик, наблюдаемый на рисунке 2, не отражается на общем графике доверия как аномалия?

Ответ: При загрузке эталонных данных «странные» значения не отбрасывались, поэтому модель приняла их как фактические значения — нужно либо отбрасывать аномальные значения, но при этом сконфигурировать так, чтобы удалились явные отклонения, но остались пики, как на графике 1, либо исключать из общего датасета значения, где ранее были зафиксированы аномалии — всё это вопрос реализации в конкретной системе.

Анализ с точки зрения злоумышленника

В данном случае злоумышленник мог бы начать первую аномальную активность параллельно во время аварии в системе — так, чтобы на его аномальное поведение внимание не обратили, а дальше держать уровень активности, аналогичной первой аномалии — это бы вошло в портрет пользователя и его могли бы не заметить.

Альтернативный подход злоумышленника — медленными изменениями активности изменить портрет активности к такому, в котором он может реализовывать свои цели — общая уязвимость для аномальных алгоритмов.

Решать описанные проблемы нужно в конкретных случаях: задать модель изучаемых данных, которая коррелирует с анализируемыми аномалиями.

Применять индивидуальную политику в принятии решения об отбрасывании «странных» значений и уведомлении об аномалиях.

Итог по TelecomX

Полученная библиотека применима к изучаемому датасету TelecomX, но полученный алгоритм анализа можно обойти, уязвимости могут скрываться как в неадекватной политике, так и в плохой модели, так и самих данных.

Анализ результатов показал, что текущая реализация подходит для быстрого и эффективно выявления аномалий в работе специализированных систем, изменения в которых почти не происходят — сервера. Для анализа пользователей применимо, но с допущениями.

Дальнейшее развитие системы

Применим полученный инструмент в анализе работы конкретной машины, трафик можно перехватывать с помощью сниффера, например, WireShark, который уже умеет агрегировать трафик и собирать статистические параметры — их останется проанализировать.

В результате анализа конкретной машины построить систему, которая выявляет нехарактерную сетевую активность.

Расширим подход в сторону анализа использования приложений, изменения файлов и журналов.

Но самое сложное - изучить, как особенности конкретного человека выражаются в активности его системы, как эти особенности выявлять и анализировать — это перспективный вопрос, для решения которого потребуется изучить психологическую, социальную программную составляющие.

Возможно, в будущем текущая работа станет шагом к лучшему пониманию человеческой природы, поможет найти ответ на вопрос как человек мыслит, и как принимает решения — без этого не выйдет эффективно решить поставленные выше задачи.

Но продвинувшись в их решении, можно будет сделать работу всех пользователей более безопасной — повышая уровень «гигиены» отдельной системы, повышаем уровень общей безопасности, как сетевой, так и социальной — контроль за девиантным поведением отдельных людей через анализ аномалий в работе их систем.

IDS система для работы с реальными данными

Выше построили библиотеку, которая может быть применена для решения задачи поиска аномальной активности — значит, и для построения IDS системы, проверили её на тестовых данных. Далее рассмотрим вопрос сбора реальных статистических данных о работе системы.

Потребуется:

1. Решить какие данные могут отражать «аномальность» действия системы
2. Как эти данные эффективно собирать, и передавать на обработку
3. Выделить модель работы пользователя с системой

От решения поставленных выше вопросов зависит успех системы в конкретном случае. Понимая, что ничего универсально-хорошего не существует, будем проектировать систему так, чтобы её могли расширить опытные пользователи, чтобы обеспечить требуемый результат в своей конкретной системе — закладываем идею расширения на этапе проектирования фундамента.

Сами же разработаем архитектуру и реализуем конкретные базовые сценарии.

Архитектура источника данных

Источник исходных данных — реализация микросервисной системы, которая инкапсулирует идею безопасности, эффективного сбора, хранения и представления исходных данных.

Подсистема состоит из 4х типов компонентов:

1. Loggers — сборщики «грязной» (исходной) информации, от их полноты зависит, какие данные впоследствии можно будет анализировать.

Требования к идеализированному сборщику:

- Эффективность — сборщики работают здесь и сейчас, параллельно с системой, не могут работать в отложенном режиме, как другие узлы системы — поэтому должны оказывать минимальный вклад в потребляемые ресурсы, не должны создавать блокировок и простоев в работе.
- Подписчик служебных событий системы — нельзя пропустить происходящее событие.

Анализируя требования, приходим к выводу — что идеализированный источник логов должен работать на низком уровне — но в целом, пользователю не запрещается использовать свой источник данных, который работает как подсистема верхнего уровня.

2. Хранилища грязных данных — обеспечивают целостность, доступность, конфиденциальность считанной информации.

Хранимые данные могут устаревать и удаляться — иначе могут вырасти до огромных размеров и перестать быть эффективными.

Могут храниться не на изучаемом устройстве, но это необязательно.

3. Представители данных — подготавливают «грязные» данные для анализа, группируют, преобразуют форматы, готовят данные для анализа анализатором.

Взаимодействуют с анализаторами:

- анализатор не может существовать без представителя информации

- представитель информации может работать с несколькими анализаторами

4. Настройки политики безопасности – политика корректирует работу описанных компонент, которые вместе образуют единую систему IDS.

(!) Это важная часть системы, и задача по её проектированию массивная – оставим её вне текущей работы, поскольку проектирование подсистемы безопасности не имеет смысла пока не будет сформировано полное представление о других компонентах системы.

Подсистема сбора/хранения/представления - сложная подсистема, которая должна соответствовать требованиям:

- Достоверность источника - нельзя допустить ложные данные об активности системы.
- Эффективность всех компонент – подсистема сбора работает здесь и сейчас, параллельно с работой системы – она не должна сильно нагружать систему в целом, быть будто в тени системы.
- Целостность хранилища – нельзя допускать несанкционированное изменение информации. Исходные данные не подлежат изменениям, их можно либо добавить, либо удалить насовсем.
- Конфиденциальность – т.к. loggers – это отдельные модули, в частности, и пользовательские расширения, то, необходимо разграничивать к хранилищу информации
- Доступность – подсистема анализа, которую рассмотрим ниже, обращается к сервисам представления и запрашивает готовые наборы данных – если будет нарушена доступность, то анализаторы могут пропустить свой этап работы, тогда политика безопасности, требующая запуск по времени, будет нарушена.

Будем называть подсистему сбора/хранения/представления – просто подсистемой представления.

Рисунок 7 Подсистема сбора/хранения/представления информации – подсистема представления.

Модель данных подсистемы представления

При проектировании конкретной системы представления требуется заранее представлять какие исходные данные могут быть использованы для анализаторов – требуется определиться с моделью данных.

Ранее рассуждали о портрете активности пользователя.

Введём классификацию подходов, к построению портрета.

1. Анализ статистической активности системы-пользователя

Необязательно связана с действиями пользователя здесь и сейчас, система может жить отдельной жизнью, но она прямо связана с детальностью пользователя.

Деятельность системы – это следствие действий пользователя, деятельность системы отражает области интересов пользователя и даёт представление о квалификации пользователя по своим настройкам – позволяет выполнить макроанализ, провести разделение пользователей на группы по интересам и квалификации.

Например:

Система А постоянно нагружена тяжёлыми процессами, постоянно обращается в соцсети, занимается парсингом комментариев в соцсетях, обучает и запускает AI, более того, в системе работают приложения, которые требуют высокий уровень квалификации. Можем сделать вывод, что владелец системы – это специалист в области искусственного интеллекта, работа его системы соответствует портрету специалистов в этой области.

Система Б не настроена, на ней установлены базовые программы из пакета программ, которые поставляются с ОС, при этом система чаще используется для сёрфинга по интернету в одном браузере – можно предположить, что владелец является рядовым пользователем ОС.

Системы А и Б отличаются:

- списком установленного ПО
- объёмом потребляемых ресурсов на единицу времени,
- возможно, периодами активности
- статистикой сетевого общения (с кем? В каком объёме? Как часто?)

Анализ активности системы как следствия характера пользователя позволяет выполнить макроанализ:

- разбить все системы на пересекающиеся группы пользователей

- отличить деятельность пользователей разных групп
- возможно отличить деятельность пользователей пересекающихся групп

НЕ позволяет:

отличить деятельность пользователей одной группы, с похожим характером активности.

2. Периферийный анализ активности пользователя

Пользователь взаимодействует с системой с помощью периферийных устройств ввода (возможно и вывода – другая тема) – анализируя их, можно получить данные для микроанализа – чтобы идентифицировать конкретного пользователя.

В частности, микроанализ позволяет понять, что пользователь взломан – т.к. работа ведётся явно другой личностью.

1. Клавиатура – наиболее часто используемое устройство ввода, им пользуются и рядовые пользователи и профессионалы.

Что можно анализировать:

- Скорость печати – простая метрика, позволяет выполнить макроанализ, отсеять опытных и неопытных пользователей.
- Частоту использования отдельных символов/спецсимволов/слов/языков/команд/сочетаний клавиш (далее будем называть это просто словами) – более сложная, но более информативная метрика.
- Характер написания – есть люди, которые формулируют свои мысли и почти не ошибаются, их характер равномерный и спокойный, при этом стирают они редко. Если же люди, которые часто перепечатывают, т.к. сомневаются, допускают орфографические ошибки или нечётко формулируют свои мысли
- Словарный запас пользователя - определить области принадлежности используемых слов, а по частоте использования слов, понять уровень вовлечённости пользователя в определённую область (25% математик, 10% пекарь, 50% безопасник...)
- По сложности используемой терминологии можно понять, квалификацию пользователя в конкретной области – новичок, любитель, профи, специалист.
- Стиль написания текстов – часто позволяет отличить некоторых колоритных личностей, тех, кто говорит и пишет в особенной манере.

Клавиатура является отличным инструментом для анализа:

позволяет составить хороший макро и микропортрет пользователя с учётом его жизненного опыта и принадлежности определённым сферам деятельности.

Более того, даже самые опытные почти не могут обойтись без клавиатуры – что делает её практически универсальным источником данных, покрывающим 99.9% пользователей.

Стоит заметить, что ту же скорость печати можно подделать (заведомо занижить), характер написания и частоту использования отдельных слов скорректировать и попытаться имитировать другого человека – таким образом, метрики в общем получаются хорошие, но поддаются подделке при использовании мощных инструментов злоумышленником, что не делает эти метрики достаточными.

Итог: анализ клавиатуры позволяет применять различные метрики (очень простые и очень сложные, но все эффективные), но обладает потенциальной возможностью подделать действия пользователя – этим страдают все рассматриваемые алгоритмы поиска аномалий, невозможно заранее гарантировать, что нельзя обойти проверки, возможно лишь их усложнить или использовать комплексно, что повысит шанс обнаружить злоумышленника.

2. Мышь - рассмотрим, как спецслужбы анализируют людей. Один из способов – анализ почерка.

Выделяют два вида анализа – графологический и почерковедческий.

Графологический анализ - используется для определения личностных черт, поведенческих особенностей, психологического состояния, состояния стресса или заболеваний. Его можно считать макроанализом – можно группировать разных людей, но отличить людей в одной группе невозможно.

Почерковедение – научный метод для определения, кто конкретно написал текст или подписал документ, используется в юриспруденции и криминалистике. Можно считать микроанализом – позволяет отличить конкретного человека.

Очевидно, что при решении нашей задачи анализ по цифровому «почерку» может стать отличным инструментом для выявления аномальной активности.

Ключевая сложность в том, что этим мало кто занимался в больших масштабах.

Назовём цифровым «почерком» - пользовательские движения мыши по экрану.

Из известного, можно выделить анализ поведения пользователя на сайтах, чтобы понять нравится или не нравится товар, например, по тому, что пользователь повёл мышь в сторону кнопки «купить» или «добавить в корзину» — частая практика, но особенность в том, что это всегда работает для конкретного частного сайта, не является универсальным решением, поскольку тут важен контекст, в рамках которого работает пользователь.

На первый взгляд, с почерком ситуация проще — исследует движения, линии, точно знаем, к какому действию они относятся, человек хотел написать «но» или «на» или «ов», понимаем цель, которую хотели достичь.

На этом этапе ПОКА начинает рассыпаться идея анализировать движение пользовательской мыши по экрану и выделять характерные движения — предполагается, что невозможно решить задачу без привязки к смыслу, если бы была известна конкретная цель, то можно было бы делать выводы.

Возможные направления для решения задачи анализа периферийных устройств

1. Анализ маршрутов, которые пользователь рисует своими движениями мыши — ОС позволяет выяснить, в каком приложении работает пользователь с помощью позволяют Main Page — страница, которая открыта поверх всех.

Далее можно сравнить эталонные маршруты работы пользователя в прошлые сеансы работы с этим приложением — предполагается, что будет характерная зависимости.

Её можно будет получить, например, если сравнить расстояния от анализируемой текущей точки маршрута мыши пользователя до ближайшей точки аналогичных маршрутов пользователя — если окажется, что маршруты «близки», то аномалии нет, в противном случае — аномалия.

2. Разбитие маршрута на сегменты по времени или длине сегмента — это может показать, насколько пользователь опытен, насколько он быстро и эффективно использует приложение.

3. Осмысление маршрутов пользователя при работе с ОС — для этого нужно отслеживать события на экране (закрытие страницы, открытие нового окна и т.д.)

Итог: Мышь является интересным устройством для получения информации для последующего исследования и выявления поведенческой аномалии, эта ниша на текущий момент плохо исследована, но определённо, она перспективна и получит развитие в будущем.

Стоит помнить, что опытные пользователи работают без мыши — только клавиатурой, сочетаниями клавиш. Более того, в случае систем без UI интерфейса, например, серверов, анализ мыши оказывается бесполезным, т.к. есть только консоль, но для анализа активности обычных пользовательских систем это почва для глубоких исследований.

3. Голосовое управление ОС — всё чаще последнее время слышно о том, что различные ОС внедряют управление голосом. Голос можно распознать — придать действиям пользователя смысл. В такой трактовке голосовые средства ввода можно считать удобными для анализа, но на текущий момент, функцией голосового управления пользуются единицы пользователей.

Направление может стать актуальным, если проекты по интеграции чипов, принесут управление системой с помощью мышления — скорее всего, они перешагнут через голосовое управление - поэтому эта сфера скорее малоактуальна.

Итого: Методы анализа поведенческих особенностей по цифровому «почерку» - крайне интересны, перспективны в силу того, что реализуют как макро, так и микроанализ — при этом, довольно характерный, если не сказать уникальный, для каждого пользователя.

Для пользовательских систем важно понимать, что конкретно сейчас пользователь действует так, если бы это был другой человек. Этого часто не хватает статическим метрикам — они могут заметить расхождения, но на это нужно больше времени, и точность может быть посредственна. Поэтому анализ цифрового «почерка» при работе пользователя вполне можно рассматривать как метрику для IPS системы, чтобы предотвращать работу уставших пользователей или злоумышленников.

Однако их внедрение требует большого исследования. Массивный камень на этом пути — это осмысление действий пользователя, если нельзя понять смысл того, что хотел пользователь, то средства анализа теряют свою целесообразность.

Как и всегда, различные средства анализа действуют совместно, для достижения поставленной цели — обеспечить безопасность.

Сбор активности с конкретного устройства

Для сбора активности можно использовать как инструменты конкретной ОС, так и библиотеки, которые эти вызовы используют, при этом представляют кроссплатформенную поддержку.

Сбор активности устройства может быть реализовать с помощью python библиотек:

Pstutil – кроссплатформенное решение, позволяет получать информацию о системе и о работающих процессах.

Можно получить более детальную информацию о использовании памяти процессорами, выявить, какие файлы открыты, сколько в них добавлено/удалено, даже на какой позиции сейчас стоит процесс.

Так же есть информация об использованном процессорном времени.

Важно заметить, что на ОС Linux возможности шире, чем на Windows.

1. GPUUtil – мощный инструмент для сбора информации о работе графического процессора (загрузка, температура, частота и т.п.)
2. Platform – позволяет получить информацию о системе, в которой работает приложение, может быть полезно при конфигурации некоторых анализаторов, чтобы принять решение как в зависимости от ОС извлекать данные.
3. Scapy – мощный кроссплатформенный инструмент для sniffing трафика и разбора содержимого пакетов. Может использоваться, как замена привычного Wireshark.

Выбор модели подсистемы представлений

Важно понимать, что оба рассмотренных подхода (статистический, периферийный) важны и должны использоваться в совокупности, в зависимости от поставленной задачи.

В рамках дипломной работы, принято решение сделать акцент на анализе системы-пользователя – макроанализ статистических отклонений в работе системы. Анализ на микроуровне планируется изучать в кандидатской работе.

За основу возьмём анализ статистической активности всей системы, с возможностью детализации по активности:

- конкретных процессов/приложений(process_activity)
- соединения(network_activity) – по IP трафику, который ходит на устройстве, с возможностью, привязать трафик к конкретному процессу и приложению – это может быть полезно при построении отчёта в момент инцидента.
- диска – операций IO в разрезе как всей системы, так и отдельных директорий/файлов.

Опытный администратор будет доволен возможностью гибко устанавливать точки контроля за своей системой.

Нетрудно догадаться, что process_activity и network_activity – это отдельные

сборщики исходной информации, задача которых сводится к тому, чтобы накапливать «грязные» данные о работе системы – логировать происходящее.

total_activity – основная таблица, которая хранить значения нагрузки на систему в интервале времени.

create_date – дискретизированное время, например, с точностью 1-10 мин.

данные об активности системы нет смысла собирать с точностью до секунды – достаточно хранить временной интервал и сохранять порядок событий.

total_activity.id – внешний ключ для таблиц детализации по процессам, т.к. позволяет привязать данные по процессам к единому временному интервалу, в который они все были записаны.

Рисунок 8 Структура таблицы total_activity

app_info – таблица для идентификации приложений, позволяет привязать процессы к приложению – инициатору.

create_date – дата добавления записи, позволяет понять, когда приложение впервые пришло в систему на анализ – может быть полезно при составлении автоматического отчёта по инциденту. Если произошла аномальная активность, то последнее добавленное приложение часто является его источником – подлежит проверке.

Рисунок 9 Структура таблицы app_info

process_activity – информация об активности конкретного процесса в конкретный ta_id.

cpu_percent – нагрузка на процессор

memory_rss – затраты физической RAM памяти

memory_vms – затраты виртуальной RAM памяти

memory_percent – процент от общей затраченной памяти.

Важно понимать, что проценты от общего возможного объёма – это нехорошая метрика, если планируется смена процессора или добавление ОЗУ – данные с процентами сразу станут бесполезны, однако на момент реализации не найден простой способ оценить загрузку процессора на Windows – он есть, можно судить по процессорному времени, но там есть тонкости.

Рисунок 10 Структура таблицы process_activity

process_connections – информация о соединениях, открытых конкретным процессом.

Позволяет сопоставить конкретный процесс с его сетевой активностью в момент времени total_activity.create_date – сетевая активность собирается отдельно и имеется информация только о порте, на котором происходит активность, без привязки к процессу и приложению.

Рисунок 11 Структура таблицы process_connections

network_activity – сетевые IPv4 IPv6 запросы

create_date и destination_port/source_port позволяют привязать сетевую активность к process_activity через process_connections и local_activity.local_ip

payload – полная информация о пакете, сжатая в специальный формат файлов PCAP.

Пользователь системы сможет в последствии просмотреть распакованный пакет в режиме просмотра или в отчёте об инциденте.

Рисунок 12 Разбор PCAP файла пакета с помощью Scapy

Рисунок 13 Структура таблицы network_activity

whois – накопление информации об ip адресах

Это может быть полезно, чтобы каждый раз не получать информацию с сервисов WHOIS, а кэшировать её в системе.

WHOIS

WHOIS – это общепринятый термин для сервиса/протокола для получения подробной информации об IP адресе. Позволяет получить информацию о:

- дате последней смены владельца домена
- владельце домена,
- стране
- компании
- и др

Полученную информацию можно использовать для небольших анализаторов подозрительной активности:

- Приложение стало обращаться к непроверенному домену или во враждебную страну.
- Если удастся расширить модель добавлением информации о компаниях – тогда можно связать конкретный запрос с конкретной компанией через IP.
- Зная конкретную компанию, можно отнести активность к тематической – по роду деятельности компании.
- Узнав конкретный domain по IP с помощью обратного DNS запроса, можно в некоторых случаях сходить на сайт компании через HTTPS – в заголовках html страницы часто будут лежать краткие описания, которые разработчики оставляют для поисковых роботов браузеров.

Итого: по IP активности потенциально можно выяснить темы, интересы, настроение пользователя – это даёт возможность для глубокого анализа целевого пользователя.

Рисунок 14 Структура таблицы whois

Полная модель хранения данных

Рисунок 15 Полная модель хранения данных

Модель данных спроектирована под анализ сетевой активности пользователя в разрезе приложений, с возможностью выстроить детализацию, как по всей системе в целом, так и по отдельным приложениям, так и по конкретным сетевым узла.

Очевидно, что модель можно расширять дальше, добавить данные журналов, дескрипторы файлов, которые используют отдельные процессы и т.д.

Демонстрационная модель на базе NoSql

При разработке оказалось удобным работать с NoSQL БД MongoDB для хранения части оперативной информации о работе системы.

Рисунок 16 Разбиение MongoDB на коллекции для эффективного поиска в разрезе времени

Для оптимизации работы с данным применяется разбиение коллекций по интервалам сбора — это позволяет равномерно наполнить и быстро извлекать данные для обучения и анализа в конкретный временной интервал.

Структура файла для MongoDB хранилища

Рисунок 17 Структура файла MongoDB

Файл содержит информацию о:

- cpu — процент загрузки, текущая частота
- times - время (пользовательское, системное, простой)
- ram — текущая загрузка оперативной памяти
- used — переключения контекста, прерывания, системные вызовы
- network — статистика по трафику
- disk — работа с диском

Большинство из этих величин, например, used — собираются на основе счётчиков самой ОС, которая копит их с момент старта — чем дольше работает система, тем больше эти счётчики.

Поэтому очевидно, что хранить их как эталонные значения бессмысленно — система работающая 1 месяц против системы, которая работает 1 час, счётчики не наберутся.

Как это работает — реализован специальный кэш, который сохраняет значение счётчика при прошлом сборе статистики (например, 1 мин назад), при новом запуске, берутся текущие счётчики, вычитается кэш — получается величина изменения за интервал времени с момента прошлого запуска сбора, это позволяет смотреть динамически на изменение ключевых параметров.

Выбор модели данных — сложный процесс, модель должна быть выбрана оптимально и обеспечивать:

- информативность
- необходимый уровень гибкости, возможность расширения
- возможность глубокой детализации для формирования отчётов об инцидентах и ведении расследований инцидентов
- Безопасна

В текущих моделях соблюдены:

- Информативность — даёт представление об активности как всей системы целиком, так и в разрезе конкретных приложений с учётом привязки сетевой активности к активности процесса конкретного приложения
- Расширяемость - для внедрения новых анализаторов
- Хороший уровень детализации в случае инцидентов — можно проследить, что происходило и кто виноват.
- Безопасна — при верной конфигурации, исходные данные скрыты за щитом представителей, и только представители имеют доступ к исходной информации. Зловред может попытаться реализовать своё расширение и попытаться средствами социальной инженерии установиться в IDS как компонент системы — тогда свойство конфиденциальности данных внутри системы будет нарушено.

Значит правами конфигурации и расширения могут обладать только ответственные пользователи.

Опасность глубокого сбора информации по пользователю

Возникает вопрос — а не слишком ли важные данные может собирать IDS, хоть и в благородных целях? Справедливо.

Концептуально собираемые данные ограничены лишь фантазией разработчика расширения к IDS системе — и это может быть очень

опасно.

Если окажется, что собираются данные, близкие к биометрии – то их нужно очень серьёзно защищать, если эта информация окажется в руках злоумышленника, который взломал IDS систему защиты с целью получения персональной информации, то он может использовать её с целью персональной атаки на конкретного пользователя – это может привести к катастрофическим последствиям.

Итог: Собираемые данные, особенно относящиеся к разряду характеризующих конкретную личность – данные для микроанализа, требуются очень хорошо защищать. В анализаторах таких данных большая сила и большая ответственность.

В частности, описанные выше статистические модели данные хороши тем, что не дают злоумышленнику биометрической информации, при этом отражают характер активности системы в течение времени – в худшем случае, злоумышленник сможет спланировать удобное время для атаки.

Подсистема анализа

Архитектура анализатора была рассмотрена выше при построении алгоритма для выявления аномалий в произвольных датасетах и принципиально не менялась.

Анализатор – приложение, которое работает по своему расписанию, запрашивает необходимые данные через представителя данных по интерфейсу, выполняет анализ каким-либо алгоритмом и сигнализирует о проблеме ответственному лицу согласно установленной политике с помощью системы уведомления.

Система поддерживает возможность добавления как новых сборщиков данных, так и представителей, так и анализаторов, так и узлов подсистемы уведомления.

Подсистема уведомления

В базовой конфигурации поставляется в качестве возможности подключить собственного телеграмм бота, который напишет о проблеме ответственному лицу, при этом подготовит полный отчёт об активности системы в момент обнаружения инцидента и по запросу в любое другое время (до, после).

Архитектура клиент-серверного взаимодействия

Все описанные выше подсистемы составляют систему анализа – система работает как служба без UI интерфейса, но предоставляет API для возможности внедрить UI интерфейс, с помощью которого администратор сможет контролировать работу системы, отбирать все данные по дате, по приложению, по адресам, просматривать содержимое запросов, строить графики, отражающие статистические отклонения, конфигурировать политики безопасности системы.

Модель UI

В ходе работы возможный UI был спроектирован, но не был реализован в силу высоких затрат на проработку серверной части – это не является серьёзным недочётом в силу того, что основное приложение серверное, а UI может быть разработан для улучшения удобства пользования.

0. При входе в систему пользователя встречает выбор профиля работы системы

Рисунок 18 Выбор профиля работы системы

В случае необходимости, системный анализатор может быстро переключиться на более строгий профиль повышенной безопасности, который потребляет значительно больше ресурсов за счёт использования тяжёлых алгоритмов анализа.

1. Главный экран представлен в виде различных детализаций, которые отражают активное состояние безопасности системы.

Рисунок 19 Актуальное состояние системы

Замечание: для дашбордов удобно использовать Elastic/Kibana/Grafana.

2. Источники данных – отражают работу сборщиков информации.

Рисунок 20 Источники информации

3. Сервисы представлений

Рисунок 21 Сервисы представлений

4. Анализаторы

Каждый анализатор имеет своё расписание работы, уровень критичности, и привязанный маршрут уведомления (Почта, телеграмм, логи)

5. Инциденты

Рисунок 22 Инциденты

Каждый анализатор в случае выявления аномальной активности, пишет инциденты.

Отчёт – это подробный сбор всех сведений о системе в момент инцидента, дополнительно можно подключить более серьёзные средства, например, анализ тяжёлыми алгоритмами, которые смогут локализовать причину – провести полное расследование.

Демонстрация работы в серверном режиме

Рисунок 23 Логи сборщика исходных данных

Рисунок 24 Работы сервиса представлений для представления типа "disk", возвращается набор для последующего обучения анализатора.

Рисунок 25 Работы сервиса представлений типа «cpu», для возврата последних данных для последующего анализа.

Рисунок 26 Логи работы анализатора типа "cpu"

Рисунок 27 Логи работы анализатора типа "disk"

Рисунок 28 Логи работы анализатора типа "network"

Заключение

Дипломная работа посвящена важной задаче обнаружения атак на компьютерные системы, методом анализа активности системы.

Данный класс проектов является очень востребованным в современной обстановке. Классические методы анализа и поиска нарушителей, основанные на базах шаблонов, себя давно исчерпали и могут лишь дополнять системы IDS и IPS. Актуальность работы подчёркивается тем, что большинство современных разработчиков систем безопасности в настоящее время либо разрабатывают подобные решения, либо уже разработали и занимаются улучшением своих продуктов.

Теоретическая ценность работы в том, что проведена классификация подходов к обнаружению аномальной активности человека-систем.

Был рассмотрен подход на анализ не только работы системы, как машины, но и активности системы, которая является следствием влияния человека – отражает его уникальные особенности, что позволяет проводить макро- и микро- анализ самого человека:

1. Можно выявлять работу третьего лица, похитителя или взломщика,
2. Оценивать изменение основных характеристик пользователя – например, уровень усталости, эффективность, концентрация внимания
3. Предотвращать не только внешние угрозы безопасности, связанные с активностью третьего лица, но и предотвращать ошибки, связанные с человеческим фактором лиц с особо важным уровнем ответственности на работе.

Практическая ценность в том, что спроектирована основа для большой платформы, которая позволит строить модульные системы анализа на основе уже созданных компонентов. Это позволит отслеживать аномальную активность не только серверных устройства, но и активность пользовательских систем.

В работе реализован эффективный алгоритм анализа систем на языке C# с учётом современных подходов к машинному обучению.

Достоинства алгоритма:

- низкие затраты мощностей системы на анализ
- низкие требования к начальному объёму исходных данных, что позволяет быстро включаться в рабочий режим анализа системы
- встроенная автоконфигурация анализаторов по произвольному датасету
- автоматический подбор весов для анализаторов, что позволяет определять корреляцию параметров с результирующим значением – выявлять важность характеристик, для которых интуитивно трудно определить уровень влияния на конечный результат.

Недостатки алгоритма:

- Нет математического обоснования того, что алгоритм работает – это интуитивный алгоритм, уверенность в работе которого базируется на практическом применении. На будущее заложены базовые понятия, которые в последствии станут основой исследований в этой области.

- Анализ активности пользовательских систем даётся труднее, чем анализ серверной активности – требуется больше данных, настройка алгоритма под конкретные задачи. Но стоит отметить, что анализ на пользовательских системах работоспособен, что показывают приведённые в работе демонстрации.

Разработана демонстрационная кроссплатформенная IDS система, включающая логгеры, сервисы представления и анализаторы. Система может быть внедрена для использования, при учёте разворота требуемого окружения.

Работа развивает направление «Модель активности компьютерных систем», способствует развитию подходов для повышения уровня безопасности отдельных устройств, руководствуясь принципом: «Безопасность отдельных устройств сети подобна личной гигиене, несоблюдение требований которой в прошлом уничтожала целые армии».

Литература

1. Шнайер Б. «Секреты и ложь. Безопасность данных в цифровом мире.» // 2003г.
2. Академия Selectel «IPS/IDS — системы обнаружения и предотвращения вторжений»

// selectel.ru [Электронный ресурс]

Режим доступа: <https://selectel.ru/blog/ips-and-ids/>

(дата обращения: 10.09.2024)

Security Vision «Методы выявления и реагирования на аномалии в компьютерных сетях.»

// securityvision.ru [Электронный ресурс]

Режим доступа: <https://www.securityvision.ru/blog/obnaruzhenie-i-predotvrashchenie-vtorzheniy/>

(дата обращения: 12.09.2024)

bastion-tech «Методы выявления и реагирования на аномалии в компьютерных сетях.» 09.12.2024

// cisoclub.ru [Электронный ресурс]

Режим доступа: <https://cisoclub.ru/metody-vyjavlenija-i-reagirovanija-na-anomalii-v-kompjuternyh-setjah/>

(дата обращения: 12.12.2024)

1. kirillkosolapov «Временные ряды в прогнозировании спроса, нагрузки на КЦ, товарных рекомендациях и поиске аномалий» 25.11.2019

// habr.ru [Электронный ресурс]

Режим доступа: <https://habr.com/ru/articles/477206/>

(дата обращения: 15.10.2024)

1. kirillkosolapov «9 подходов для выявления аномалий» 26.11.2019

// habr.ru [Электронный ресурс]

Режим доступа: <https://habr.com/ru/articles/477450/>

(дата обращения: 15.10.2024)

1. Jaulla «Рекомендательные системы: проблемы и методы решения. Часть 1» 14.07.2021

// habr.ru [Электронный ресурс]

Режим доступа: <https://habr.com/ru/companies/prequel/articles/567648/>

(дата обращения: 15.10.2024)

Arenadata «Открытый датасет TelecomX» 06.11.2024

// habr.ru [Электронный ресурс]

Режим доступа: <https://habr.com/ru/companies/arenadata/articles/856366/>

(дата обращения: 15.01.2025)

Arenadata «Открытый датасет TelecomX » 06.11.2024

// data.mendeley.com [Электронный ресурс]

Режим доступа: <https://data.mendeley.com/datasets/3t6rbtcms8/1>

(дата обращения: 11.12.2024)

learn.microsoft.com «Образцы баз данных AdventureWorks» 19.11.2025

// learn.microsoft.com [Электронный ресурс]

Режим доступа: <https://learn.microsoft.com/ru-ru/sql/samples/adventureworks-install-configure?view=sql-server-ver16&tabs=ssms>

(дата обращения: 15.12.2025)

nulovkin «Простейшая нейросеть: еще раз и подробнее» 06.02.2023

// habr.ru [Электронный ресурс]

Режим доступа: <https://habr.com/ru/articles/714988/>

(дата обращения: 17.10.2024)

1. scottplot.net «ScottPlot - Interactive Plotting Library for .NET » 11.10.2025

// scottplot.net [Электронный ресурс]

Режим доступа: <https://scottplot.net>

(дата обращения: 19.11.2025)

docs-python.ru «Функции для работы с PID модуля psutil в Python»

// docs-python.ru [Электронный ресурс]

Режим доступа: <https://docs-python.ru/packages/modul-psutil-python/spisok-zapushchennykh-protsessov/>

(дата обращения: 29.12.2025)

BOTCODERS «Получение информации о системе с помощью Python» 08.12.2024

// habr.ru [Электронный ресурс]

Режим доступа: <https://habr.com/ru/articles/864830/>

(дата обращения: 30.09.2025)

scapy«Starting Scapy»

// scapy.readthedocs.io [Электронный ресурс]

Режим доступа: <https://scapy.readthedocs.io/en/latest/usage.html>

(дата обращения: 25.11.2025)

GolovinDS «Изучаем протоколы со Scapy» 14.01.2022

// habr.ru [Электронный ресурс]

Режим доступа: <https://habr.com/ru/companies/otus/articles/645627/>

(дата обращения: 25.11.2025)

BOTCODERS «Получение информации о системе и сети с помощью Python» 15.12.2024

// habr.ru [Электронный ресурс]

Режим доступа: <https://habr.com/ru/articles/866788/>

(дата обращения: 05.11.2025)

Приложение А. Описание репозитория

С исходниками можно ознакомиться на открытом GitHub репозитории https://github.com/SkibaSAY/IPS_University.

Репозиторий состоит из нескольких проектов, в дипломной работе задействованы некоторые из них:

1.IDS_BL (https://github.com/SkibaSAY/IPS_University/tree/master/IDS_BL)

- Python (3.12.7) для логгеров активности и подсистемы представлений.

2.IPSLib (https://github.com/SkibaSAY/IPS_University/tree/master/IPSLib) -

Библиотека на C# (.NET 8.0) с алгоритмом анализа, примерами применения библиотеки на датасете TelecomX и примером с запуском полноценной IDS системы анализа аномальной активности в разрезе конкретной системы.

3.IpsExampleConsole (https://github.com/SkibaSAY/IPS_University/tree/master/IpsExampleConsole) – консольное приложение для запуска демонстрационных примеров из пункта 2.

В следующих приложениях рассмотрим код методов бизнес логики.

Приложение Б «Реализация логгеров»

API и точка запуска

Главный файл для запуска `logger_total_api.py`

Запускается через консоль командой

```
uvicorn logger_total_api:app --reload --port 8000
```

Требование: может потребоваться запуск от имени администратора – для части сбора логов, особенно, если это касается sniffing трафика.

Бизнес логика

`loggers\machine\machine.py`

Использует менеджер

`loggers\machine\stat_managers\cpu.py`

Именно в нём скрывается сбор актуальной статистики.

`AbsoluteDictStat`

- предназначен для сбора изменений абсолютных параметров.

Абсолютные параметры – это параметры, построенные на неубывающих счётчиках системы, которые копятя с момента старта.

Работать с абсолютными параметрами неудобно в разрезе анализа, а вот с тем, как эти параметры меняются в разрезе времени – очень удобно.

Например, статистика по затраченному времени:

- Системой
- Пользователем
- Простоем системы

`ScheduleLogger`

Инкапсулирует в себе базовую логику логгера, который запускается по расписанию в отдельном потоке.

Приложение В Реализация сервиса представлений

Точка запуска и API

`view_service_total_api.py`

Бизнес логика

`view_services\total_manager.py`

Помимо описанного в проекте реализовано много наработок для других логгеров – например, логгер гри и активности в разрезе процессов.

Приложение Д Реализация анализатора

Анализатор реализован в библиотеке C#

https://github.com/SkibaSAY/IPS_University/tree/master/IPSLib

Лучше всего начинать изучение с того, как устроен анализатор (планирование), далее переходить к реализации алгоритма.

Реализация IDS системы, которая работает на тех данных, которые поставляют сервисы представления.

https://github.com/SkibaSAY/IPS_University/tree/master/IPSLib/Examples/MachineIDS

Каждый из имеющихся анализаторов наследуется от базового класса, им важно лишь указать тип представления, в который требуется обращаться за данными.

Алгоритм анализа

Основной класс

https://github.com/SkibaSAY/IPS_University/blob/master/IPSLib/EstimationPredictors/DeterminePredictor/DeterminePredictor.cs

Основные функции